

Smart Contract Re-audit Report

MoonsaleToken

BNB Smart Chain · Solidity ^0.8.20

ENGAGEMENT METADATA

REPORT ID	ICG-2026-MSL-006 (Re-audit R2 of MSL-002)
CLIENT	Moonsale App
SCOPE	MoonsaleToken.sol (R2 revision)
COMMIT / VERSION	Single source file, 98 SLOC, second-round remediation revision
METHODOLOGY	Manual re-audit, remediation verification
ISSUE DATE	April 23, 2026

Executive Summary

This report is the second re-audit of MoonsaleToken, following the client's remediation of the findings raised in ICOGemHunters re-audit ICG-2026-MSL-004 (R1, April 23, 2026). The revised source is 98 SLOC, up from 86 in R1 and 45 in the original MSL-002 review. The added code closes two of the three Informational items from R1 with targeted, minimal changes: a constructor invariant that rejects the previously contradictory `mintable_ = true, maxSupply_ = 0` combination, and a new `burnFrom` function that exposes the allowance-aware burn pattern expected by staking, bridge, and vault integrations.

Of the 3 findings raised in R1: 2 are now fully Fixed (I-R1, I-R2), and 1 is Acknowledged as an accepted build-pipeline trade-off (I-R3, the compiler EVM target). No new findings were identified in this round. The re-audit therefore produced 0 Critical, 0 High, 0 Medium, 0 Low, and 0 Informational new findings, with 1 carryover Acknowledged item.

The fixes were verified directly. I-R1's invariant `require(!mintable_ || maxSupply_ > 0)` at line 44 reduces the deploy-time parameter space to semantically consistent combinations only: fixed-supply tokens use the `maxSupply_ = 0` sentinel with `mintable_ = false`, while mintable tokens must declare an explicit non-zero cap. I-R2's `burnFrom` uses OpenZeppelin's `_spendAllowance` followed by `_burn`, preserving the atomicity and allowance-refund semantics of the canonical `ERC20Burnable` pattern. The new function emits `TokensBurned` with the account (not `msg.sender`) as the indexed field, which is the correct choice for indexers tracking balance changes.

The security score rises from 93/100 at R1 to 97/100 at R2, a cumulative improvement of 25 points from the original 72/100 assessment. The 3-point residual reflects the Acknowledged compiler target concern and a general reserve for items outside the manual-review scope such as formal verification. No findings block deployment. The contract is production-ready and has reached a stable end-state for its design intent.

Score Progression

	Original (MSL-002)	R1 (MSL-004)	R2 (MSL-006)
Critical	0	0	0
High	1	0	0
Medium	3	0	0
Low	3	0	0
Info	2	3	0 new · 1 ack
Total new findings	9	3	0
Security Score	72 / 100	93 / 100	97 / 100

Remediation Status (R1 Findings)

The 3 findings raised in re-audit R1 (ICG-2026-MSL-004) were each verified against the R2 source. The table below lists each R1 finding with its current status and a verification note referencing the implementing line or design decision.

ID	Sev	Title	Status	Verification Note
I-R1	Info	maxSupply_ sentinel overload with mintable_=true	Fixed	require(!mintable_ maxSupply_ > 0) added at line 44. Rejects the contradictory mintable_=true with maxSupply_=0 combination at construction. Matches Option A of the R1 recommendation exactly.
I-R2	Info	No allowance-based burn path	Fixed	burnFrom(address account, uint256 amount) added at lines 91-97. Uses _spendAllowance and _burn with proper isBurnable gate and amount validation. Emits TokensBurned with the account (not caller) as the indexed field. Matches ERC20Burnable semantics.
I-R3	Info	Compiler EVM target for BSC	Acknowledged	Deployment-time note, unchanged. Confirm Shanghai support on target nodes before deploying.

Scope & Methodology

In-Scope Files

File	Role	Reviewed
MoonsaleToken.sol	Standard ERC-20 with optional owner-gated mint and public self-burn plus allowance-based burn; second-round remediation revision after MSL-004	Yes

R2 Methodology

- Diff between MSL-004 source (86 lines) and R2 source (98 lines), with the 3 R1 findings used as an explicit verification checklist.
- Verified the new constructor invariant at line 44: traced parameter combinations to confirm that `mintable_ = true`, `maxSupply_ = 0` is now rejected while all legitimate fixed-supply and expandable-supply configurations remain reachable.
- Walked the new `burnFrom` function: confirmed checks-effects-interactions, confirmed the `isBurnable` gate and `amount > 0` check, and confirmed that `_spendAllowance` correctly decrements caller's allowance with `revert-on-insufficient-allowance`.
- Verified that a `revert` inside `_burn` (for example, insufficient balance) will revert the entire transaction, restoring the allowance decrement performed by `_spendAllowance`; no state desynchronization is possible.
- Checked that `TokensBurned` events from `burn` and `burnFrom` both use the account whose balance was burned as the indexed field, giving indexers a consistent filter key regardless of who initiated the burn.
- Fresh pass over the full contract to detect any knock-on effects from the two changes; none were identified. The core accounting paths, access control, and event coverage are unchanged from R1.

Severity Classification

Severity	Definition
----------	------------

Critical	Direct loss of user or protocol funds, or unilateral takeover.
High	Realistic exploit with significant impact.
Medium	Conditional impact or material UX or availability concern.
Low	Limited impact; defence in depth.
Informational	Code quality, gas, documentation.

New Findings

No new findings were identified in this round. The R2 revision adds two targeted changes (I-R1 constructor invariant and I-R2 `burnFrom` function); each was verified to be correct, to preserve the prior safety properties, and to introduce no new attack surface.

Carryover Acknowledged Items

One R1 item remains Acknowledged rather than Fixed. It is not a vulnerability in the traditional sense; it is a build-pipeline concern outside the contract source.

- I-R3 Compiler EVM target. `pragma solidity ^0.8.20` with default settings emits PUSH0. BSC mainnet supports Shanghai; deployments to forked, archive, or lagging nodes require explicit settings: `{ evmVersion: "paris" }` in the build configuration. This is addressed at the build-pipeline level, not in the contract source.

Positive Observations

- Round-2 remediation mirrors the R1 recommendations verbatim: I-R1 implements Option A (on-chain constructor check), I-R2 implements the suggested `burnFrom` with the exact code template provided in the R1 report.
- The new invariant `require(!mintable_ || maxSupply_ > 0)` collapses two orthogonal concerns (capability and cap) into a single deploy-time check that admits only semantically coherent configurations. Fixed-supply tokens still use the elegant `maxSupply_ = 0` sentinel, preserving the clean API.
- `burnFrom` delegates allowance handling to OpenZeppelin's `_spendAllowance`, which correctly implements the infinite-allowance bypass (spending from `type(uint256).max` does not decrement), matching the behaviour expected by integrators familiar with ERC20Burnable.
- Event emission in `burnFrom` uses the burned-account as the indexed field, which is the correct subgraph filter key. Integrators can track per-account burn history without distinguishing between self-burn and allowance-burn paths.
- The allowance decrement in `_spendAllowance` and the balance decrement in `_burn` are atomic: any revert within `_burn` reverts the entire transaction and restores the allowance, so no desynchronized-state window exists.
- The R2 surface remains minimal: no external calls, no loops, no reentrancy vector, no upgradeability, no selfdestruct. The only mutable storage variable after deployment is still the single `mintingActive` bool.
- The `burnFrom` function is correctly placed outside any `onlyOwner` gate; anyone with a valid allowance can call it, matching the canonical ERC-20 allowance model.
- Every R1 and original-audit finding ID still appears as an in-code comment (`// H-01, // I-R1, // I-R2, etc.`), providing a complete audit trail across all three review rounds.

Out of Scope and Assumptions

- OpenZeppelin v5 base contracts (ERC20, Ownable) are not re-audited and are assumed canonical. The `_spendAllowance` and `_burn` internals are assumed to behave as documented in OpenZeppelin v5.
- The `MoonsaleTokenFactory` that deploys this contract remains out of scope.
- The deploy-time values of `mintable_`, `burnable_`, `totalSupply_`, and `maxSupply_` are determined by the factory or end user. The R2 revision tightens the allowed parameter space but further validation (such as reasonable `maxSupply` magnitude, decimals sanity) remains at the factory UI layer.
- Deployment is assumed to target a Shanghai-enabled EVM as discussed in I-R3.
- No off-chain components are in scope.

Summary and Final Position

The R2 revision of MoonsaleToken closes every actionable finding from the R1 re-audit. Two of the three R1 items are Fixed with code-level changes that match the prior recommendations verbatim; the remaining item is formally Acknowledged as a build-pipeline concern outside the contract source. No new findings were introduced. The contract's invariant structure is now tight: capability flags and supply cap are constrained to semantically coherent combinations at construction, the allowance-based burn path is present for integrations, and the admin surface remains minimal with the one-way disableMinting lifecycle exit already in place from R1.

Engagement Progression

The contract has undergone three rounds of review: the original audit (MSL-002, score 72/100) identified 9 findings including 1 High severity (unbounded owner mint). The R1 re-audit (MSL-004, score 93/100) verified the resolution of all 9 prior findings and surfaced 3 Informational items. This R2 re-audit (MSL-006, score 97/100) confirms the resolution of 2 of those 3 R1 items and records the remaining 1 as an accepted build-pipeline trade-off, with no new findings. The contract is production-ready and has reached a stable end-state.

SECURITY SCORE

72 → 93 → 97 / 100

Disclaimer

This report is a point-in-time second re-audit of the source code revision provided to ICOGemHunters following the remediation of audit MSL-004. Findings reflect the state of the code at the commit or version indicated on the cover page. Any modification made after that point, whether by the client or a third party, invalidates the specific conclusions drawn herein.

The assessment is advisory. It does not constitute a warranty, guarantee, or insurance policy against exploits, operational failures, or economic losses. Smart contract security cannot be proven exhaustively; the absence of a finding is not a proof of absence of vulnerability. ICOGemHunters applied professional diligence and the methodology described in this document, no more and no less.

This report is not financial, legal, tax, or investment advice. Nothing in this document should be interpreted as an endorsement of the token, project, team, or any associated economic activity. Decisions to acquire, hold, transact in, or interact with MoonsaleToken remain the sole responsibility of the user.

ICOGemHunters accepts no liability for losses, damages, or consequences arising from the client's decision not to implement the recommendations contained in this report, or from reliance on this report by any third party. The report is prepared for the named client and may not be reproduced in part without preserving this disclaimer in full.

The Acknowledged item in this report reflects an explicit build-pipeline decision communicated by the client. The client's acceptance of this trade-off does not transfer liability to ICOGemHunters; operators should verify Shanghai-EVM compatibility on all target nodes before deploying MoonsaleToken.

For questions, clarifications, or a further re-assessment after additional remediation, contact ICOGemHunters through the channels published at the website listed on the cover page.

Both deployable tokens in the Moonsale engagement have now completed their remediation cycles: MoonsaleLiquidityToken at 94/100 (MSL-005) and MoonsaleToken at 97/100 (this report). The MoonsaleTokenFactory that deploys both remains the only unreviewed component and should be submitted for a separate audit to close the loop on the full deployment pipeline.